

Section 07



Industrial Security (Master)

Section 07 – Safety / Security Co-Engineering

Safety / Security Co-Engineering

Lecture Notes

Department of Computer Science

- 1 Two Disciplines, One Plant
- 2 Joint Workshops
- 3 SIS as Target
- 4 Regulatory Alignment

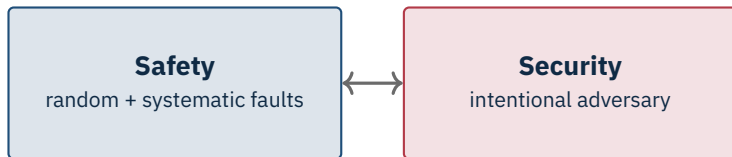
By the end of this section you will be able to

- Articulate the historical separation between functional safety and cyber security teams.
- Map IEC 61508/61511 (safety) onto IEC 62443 (security) on a shared lifecycle.
- Conduct a combined Cyber-HAZOP / SECOP workshop.
- Use SIS-aware threat modelling (TRITON case study).
- Build a co-engineering programme that satisfies both regulators.

1

Two Disciplines, One Plant

Section 07 – Safety / Security Co-Engineering



Where they overlap

Both protect the same physical process. A successful attack on the SIS is, by definition, a safety event. Treating them in separate org silos guarantees blind spots.

Source: ISA-99 & IEC working group joint statements, 2014–2018.

Concept & scope – safety: HAZID + IEC 61511; security: IEC 62443-3-2 zones

Hazard / risk analysis – HAZOP → Cyber-HAZOP joint

Overall safety / security requirements

Allocation – SIF + SL-T per zone

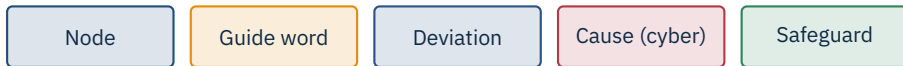
Verification, validation, operation, modification

Source: ISA TR84.00.09:2017 explicitly aligns the lifecycles.

2

Joint Workshops

Section 07 – Safety / Security Co-Engineering



Cross-disciplinary team

Process safety engineer + control engineer + cyber-security architect + (when SIS in scope) functional safety engineer. Operations sits in the room.

Source: IEC 61882:2016 (HAZOP) | ISA TR84.00.09 | CCPS Guidelines for Engineering Design for Process Safety, 2012.

Guide	Param	Cyber cause	Safeguard	Gap
More	Flow	HMI compromise raises setpoint	High-flow alarm; SIS @ 1.3×	No write allow-list
No	Cool	Attacker stops fan PLC (S7comm)	Operator alarm; thermal SIS trip	No CPU mode-change alert
Less	Press.	Attacker disables relief valve sol.	Mechanical relief, second SIS	No PLC code integrity check

- Each gap gets an owner (safety, security, operations).
- Each gap is sized: control change vs. engineering change vs. procurement change.
- Each gap has a deadline tied to the next plant turnaround.
- Findings are tracked alongside the SIL verification record.

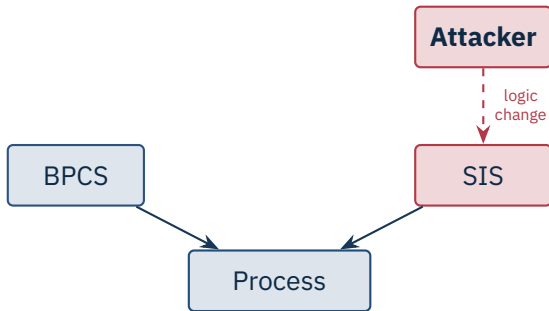
Common artefact

A single *Process Hazard & Cyber-Hazard Register* – one row per hazard, with both safety and security mitigations – is far more useful than two parallel registers.

3

SIS as Target

Section 07 – Safety / Security Co-Engineering



TRITON 2017 was the proof

The attackers reached the Triconex SIS via the proprietary TriStation protocol. A bug in the malware tripped the plant; without the bug, the SIS would have permitted unsafe states.

Source: Dragos TRISIS Malware Analysis, 2017 | Mandiant/FireEye TRITON report, 2017.

- Where is the SIS reachable from? (engineering WS, vendor laptop, jump host).
- How is logic downloaded? (proprietary protocol, signed?, key-switch?).
- Who can change the SIL target without re-validation?
- How would tampering be detected? (checksum, log).
- How would the operator know an SIS trip was inhibited?

Caution

Any answer that ends with “vendor tool tells us” is not a control. Vendor tools can be spoofed.

Physical key-switch in RUN, key under dual control

Dedicated engineering WS, no Internet, no shared logins

Continuous SIS code-checksum monitoring (vendor or third-party)

Physical inspection schedule for proof tests

4

Regulatory Alignment

Section 07 – Safety / Security Co-Engineering

	Safety	Security
Standard	IEC 61508 / 61511	IEC 62443, NIST CSF
Regulator (DE)	BAuA, Berufsgenossenschaft	BSI (KRITIS), NIS2 authority
Audit focus	SIL validation, proof tests	risk assessment, controls, IR
Frequency	1–3 years	annual + on-incident

Calendar trick

Schedule cyber-relevant safety reviews and security audits in the same window. One outage, two regulators happy.

Joint risk register (single source of truth)

Shared change-management board (safety + security + ops)

Combined training (operators understand cyber, IT understands SIS)

Common metrics: incidents, near-misses, gap closure

Coordinated tabletop exercises

- Safety engineers see security as “IT noise”.
- Security engineers see safety as “slow and process-heavy”.
- Operations sees both as obstacles to uptime.
- Vendors split safety + security across separate product lines.

Bridge person

A single named individual with both safety and security training is worth a binder of policy. Hire or grow one.

★ Key Takeaway: Safety and security on one plant

- The lifecycles align cleanly – IEC 61511 + IEC 62443-3-2 share most artefacts.
- Joint Cyber-HAZOP / SECOP workshops surface gaps neither side would find alone.
- TRITON demonstrated that attackers will pursue the SIS specifically.
- Compensating controls for legacy SIS exist; use them while the next CAPEX cycle runs.
- Single risk register, single change board, combined training – and a bridge person.

- IEC 61508 (ed. 2.0, 2010). *Functional safety of E/E/PE safety-related systems*.
- IEC 61511 (ed. 2.0, 2016/17). *Functional safety – SIS for process industry*.
- IEC 62443-3-2:2020. *Security risk assessment for system design*.
- ISA TR84.00.09:2017. *Cybersecurity related to the Functional Safety Lifecycle*.
- IEC 61882:2016. *HAZOP studies – Application guide*.
- CCPS. *Guidelines for Engineering Design for Process Safety*, 2012.
- Dragos. *TRISIS Malware Analysis*, 2017.
- Mandiant/FireEye. *Attackers Deploy New ICS Attack Framework “TRITON”*, 2017.
- Schneider Electric. *Triconex Top Model 3008 – TRITON Lessons Learned*, 2018.
- Stoll, P. *Integrating Functional Safety and Cybersecurity in the Process Industries*, 2020.
- BSI. *IT-Grundschutz Bausteine relevant to OT*.
- European Process Safety Centre. *Joint cyber-safety guidance*, 2021.

End of Section 07



Safety / Security Co-Engineering

Questions and discussion